

INFORME DE CIBERINTELIGENCIA

Análisis de Campaña de Phishing

Suplantación de Correos España

CAMPO	DETALLE
Fecha del análisis	18 de abril de 2026
Herramienta principal	Maltego Graph Desktop 4.11.2
Objetivo del análisis	Identificación de infraestructura de phishing
Dominio investigado	correos-pago.com
Clasificación	CONFIDENCIAL – Solo uso educativo

1. RESUMEN EJECUTIVO

Durante esta sesión práctica de ciberinteligencia se llevó a cabo un análisis OSINT completo utilizando Maltego como herramienta principal. El objetivo fue identificar y documentar la infraestructura de una campaña de phishing activa que suplantaba la identidad de Correos España, una de las marcas más suplantadas en España en 2026.

El análisis permitió mapear completamente la infraestructura maliciosa, identificar técnicas de evasión utilizadas por el actor amenaza, y comparar la infraestructura legítima de Correos con la fraudulenta.

HALLAZGO PRINCIPAL

El dominio correos-pago.com fue registrado el 24 de diciembre de 2025 (Nochebuena) utilizando triple capa de anonimato: registrante REDACTED, DNS de Njalla y contacto vía Tiered Access. El dominio estaba alojado en Saint Kitts y Nevis (KN), jurisdicción de difícil rastreo legal.

2. METODOLOGÍA

Todo el análisis se realizó mediante técnicas OSINT (Open Source Intelligence), consultando exclusivamente fuentes de información públicamente disponibles. No se accedió a ningún sistema sin autorización.

2.1 Herramientas utilizadas

HERRAMIENTA	USO	TIPO
Maltego 4.11.2	Mapeo de infraestructura	Principal
Have I Been Pwned	Detección de filtraciones	Gratuito
ViewDNS.info	Reverse IP lookup	Gratuito
VirusTotal	Análisis de reputación	Gratuito
WHOIS / who.is	Datos de registro de dominios	Gratuito
Shodan.io	Puertos y servicios expuestos	Freemium

3. ANÁLISIS DE INFRAESTRUCTURA LEGÍTIMA

Como punto de partida y referencia comparativa se analizó la infraestructura oficial de Correos España (correos.es).

3.1 Subdominios identificados en correos.es

SUBDOMINIO	FUNCIÓN
mail.correos.es	Servidor de correo principal
mail1.correos.es	Servidor de correo secundario
webmail1.csp.correos.es	Portal webmail empleados
webmail2.csp.correos.es	Portal webmail empleados (backup)
accesointranetseguro.correos.es	Acceso remoto intranet corporativa
vofnet.correos.es	Red corporativa
ac2.sel.correos.es	Servicios internos

4. ANÁLISIS DEL DOMINIO MALICIOSO

4.1 Datos WHOIS de correos-pago.com

CAMPO WHOIS	VALOR
Fecha de registro	24/12/2025 (Nochebuena)
Fecha de expiración	24/12/2026
Registrador	Tucows Domains Inc.
Registrante	REDACTED FOR PRIVACY
Organización	REDACTED FOR PRIVACY
País	Saint Kitts and Nevis (KN)
Nameserver 1	1-you.njalla.no (185.193.124.2)
Nameserver 2	2-can.njalla.in (185.193.124.34)
Nameserver 3	3-get.njalla.fo (95.215.19.5)
Contacto abuso	tieredaccess.com (servicio de privacidad)
Estado	clientTransferProhibited / clientUpdateProhibited

4.2 Subdominios del dominio malicioso

Maltego identificó los siguientes subdominios activos en correos-pago.com:

SUBDOMINIO	ANÁLISIS
sms.correos-pago.com	Envío de SMS masivos – CRÍTICO
mail.correos-pago.com	Servidor de correo fraudulento
www.correos-pago.com	Web principal de phishing
pox.correos-pago.com	Servidor desconocido
pm.correos-pago.com	Panel de mando probable
hostmaster.webmail.*	Infraestructura de soporte

5. TÉCNICAS DE EVASIÓN IDENTIFICADAS

TRIPLE CAPA DE ANONIMATO

El actor amenaza utilizó una combinación de tres capas de anonimato para dificultar su identificación: (1) Privacidad WHOIS vía Tiered Access, (2) DNS anónimo vía Njalla, (3) Jurisdicción offshore en Saint Kitts y Nevis.

5.1 Descripción de cada técnica

Registro en Nochebuena (24/12/2025)

Técnica clásica para evitar detección temprana. Los equipos de seguridad operan con personal reducido durante las festividades, lo que permite a los dominios maliciosos operar sin ser reportados durante los primeros días críticos de la campaña.

Njalla como proveedor DNS

Njalla es un servicio de DNS y registro de dominios diseñado específicamente para el anonimato máximo. Fue fundado por Peter Sunde, cofundador de The Pirate Bay. Njalla actúa como propietario legal de los dominios registrados, haciendo imposible identificar al cliente real mediante procesos legales ordinarios.

Saint Kitts y Nevis como jurisdicción

País caribeño con escasa regulación en materia de cibercrimen y cooperación judicial internacional limitada. Muy utilizado por actores maliciosos para dificultar la retirada legal de dominios y el rastreo de responsables.

Tiered Access para contacto

Sistema de privacidad de contacto que cumple con las políticas ICANN de acceso escalonado a datos WHOIS. Proporciona una capa adicional de privacidad que requiere justificación formal para revelar los datos reales del registrante.

Estado clientTransferProhibited

El dominio fue bloqueado para transferencias y modificaciones desde el momento del registro. Esto dificulta que los equipos de respuesta a incidentes o los registradores puedan tomar el control del dominio rápidamente.

6. COMPARATIVA: LEGÍTIMO VS FRAUDULENTO

INDICADOR	correos.es (LEGÍTIMO)	correos-pago.com (FRAUDULENTO)
TLD	es (oficial español)	com (genérico)
Registrante	Correos y Telégrafos S.A.	REDACTED
País	España	Saint Kitts y Nevis
DNS	Propios de Correos	Njalla (anónimo)
Subdominio SMS	No existe	sms.correos-pago.com
Antigüedad	Décadas de historia	Registrado en festivo 2025
Estado web	Activa y operativa	Inactiva (campaña finalizada)

7. CICLO DE VIDA DE LA CAMPAÑA

Basado en el análisis realizado, se reconstruye el ciclo de vida probable de esta campaña de phishing:

FASE	FECHA APROX.	ACTIVIDAD
1	24/12/2025	Registro del dominio en Nochebuena vía Tucows/Njalla
2	Dic 2025 – Ene 2026	Configuración de infraestructura: SMS, web de phishing, panel de control
3	Mar 2026	Lanzamiento de campaña masiva de SMS suplantando a Correos (+120 dominios activos en España)
4	Mar – Abr 2026	Recolección de credenciales bancarias y datos personales de víctimas
5	Abr 2026	Desactivación del servidor. Dominio sin respuesta (ERR_CONNECTION_TIMED_OUT)

8. HALLAZGOS ADICIONALES

8.1 Filtraciones del email investigado

Durante el análisis se comprobó también la huella digital de un usuario usando Have I Been Pwned. El email analizado apareció en dos filtraciones importantes:

FILTRACIÓN	DESCRIPCIÓN
SynthientCredentialStuffing	Lista de credential stuffing recopilada de múltiples brechas previas. Usada para ataques automatizados.
TelegramCombolists	Lista masiva distribuida en grupos de Telegram con emails y contraseñas robadas.

8.2 Infraestructura de El Corte Inglés (ejercicio adicional)

Como ejercicio complementario de brand protection se analizó la infraestructura de El Corte Inglés, identificando:

- IP central 185.90.81.234 alojando más de 40 dominios corporativos del grupo
- ASN propio: AS204643 (ECI) con infraestructura en Madrid vía Telefónica
- Bloque de red 194.179.126.0/24 con 24 IPs activas para intranet corporativa
- Subdominio intranet.elcorteingles.es accesible desde internet con IP pública
- Servidor FTP activo: ftp.elcorteingles.es (protocolo legacy de riesgo)
- Protección de email activa (mail.protection) contra phishing entrante

9. CONCLUSIONES Y RECOMENDACIONES

9.1 Conclusiones del análisis

- El dominio correos-pago.com forma parte de una campaña organizada de phishing con infraestructura profesional
- El actor amenaza demuestra conocimiento avanzado de técnicas de anonimato y evasión

- La elección de Njalla como DNS y Saint Kitts como jurisdicción indica un actor con experiencia en evasión de takedowns
- El subdominio sms.correos-pago.com confirma capacidad para envío masivo de SMS fraudulentos
- La campaña ya estaba inactiva en el momento del análisis, pero el dominio sigue registrado

9.2 Recomendaciones

PRIO.	RECOMENDACIÓN
ALTA	Reportar correos-pago.com a INCIBE (017) y a Google Safe Browsing para bloqueo en navegadores
ALTA	Cambiar contraseñas de cualquier servicio asociado al email analizado y activar 2FA
MEDIA	Monitorizar registro de nuevos dominios con patrón correos-* para detección temprana
MEDIA	Revisar el servidor FTP de El Corte Inglés (ftp.elcorteingles.es) como parte de auditoría de seguridad
BAJA	Implementar alertas automáticas en DomainTools o SecurityTrails para dominios similares a la marca

10. MARCO LEGAL Y ÉTICO

AVISO LEGAL IMPORTANTE

Todo el análisis realizado en este ejercicio se basó exclusivamente en fuentes de información públicamente disponibles (OSINT). No se accedió a ningún sistema informático sin autorización, no se realizaron ataques ni se comprometió ningún sistema. Este informe tiene únicamente finalidad educativa y de investigación en ciberseguridad.

ACCIONES REALIZADAS (LEGAL)	ACCIONES NO REALIZADAS (ILEGAL)
Consulta de registros DNS públicos	Acceso a sistemas sin autorización
Consulta de bases de datos WHOIS	Explotación de vulnerabilidades
Análisis de información pública	Interceptación de comunicaciones
Consulta de Have I Been Pwned	Recolección de datos personales sin consentimiento
Análisis pasivo de infraestructura	Doxing o acoso a personas

Informe generado como ejercicio práctico de ciberinteligencia | Uso exclusivamente educativo